

TSEC Risk & Cyber Advisory LLC

Integrated Cybersecurity, Risk & Compliance Advisory

TSEC-FREE-007

Security Awareness Checklist

Annual Security Awareness Program — Planning & Completion Tracker

NIST SP 800-50 | ISO/IEC 27001:2022 A.6.3

Document ID:	TSEC-FREE-007
Version:	1.0
Date:	June 2026
Classification:	CONFIDENTIAL
Prepared by:	TSEC Risk & Cyber Advisory LLC

www.tsecgrc.com | info@tsecgrc.com

1. Program Overview

A robust security awareness program is a foundational control for every compliance framework. This checklist helps security teams plan, execute, and document annual security awareness activities. Mark each item upon completion and retain this record for audit purposes.

2. Annual Training Requirements

Mandatory Training — All Staff		
#	Control / Requirement	Status (✓/X/NA)
1	Annual security awareness training completed and documented (all employees).	
2	New hire security orientation conducted within first 30 days of employment.	

3	Phishing simulation campaign conducted (minimum quarterly).	
4	Social engineering awareness training included in annual curriculum.	
5	Data handling and classification training completed by all staff.	
6	Password hygiene and MFA usage training delivered.	
7	Incident reporting procedures communicated and understood by all users.	
8	Acceptable Use Policy acknowledged (signed or electronic confirmation) annually.	

3. Role-Based Training

Targeted / Role-Based Training		
#	Control / Requirement	Status (✓/X/NA)
1	Privileged users (IT Admins): advanced security operations and hardening training.	
2	Developers: secure coding practices training (OWASP Top 10 minimum).	
3	Finance / Accounting: BEC (Business Email Compromise) and wire fraud awareness.	
4	HR / Recruiting: social engineering and credential phishing targeting HR workflows.	
5	Executives / Board: cyber risk governance, board-level security briefing conducted.	
6	Third-party contractors: security requirements communicated and acknowledged.	

4. Program Documentation

Recordkeeping & Evidence		
#	Control / Requirement	Status (✓/X/NA)
1	Training completion rates tracked and reported (target: 95%+ completion).	
2	Phishing simulation results documented with click rates and trend analysis.	
3	Non-completions followed up and escalated to management after 30-day grace period.	
4	Training materials reviewed and updated annually to reflect current threat landscape.	
5	Training records retained for minimum 3 years for audit and regulatory purposes.	
6	Security awareness program effectiveness metrics reported to CISO/management.	

5. Completion Summary

Training Module	Completion Date	Completion Rate	Reviewer
Annual Security Awareness			
Phishing Simulation Q1			
Phishing Simulation Q2			
Phishing Simulation Q3			
Phishing Simulation Q4			
Role-Based Training			
New Hire Orientation			